
Informe Profesional de Pentesting

Actividad A08 — Hacking Etico

Cliente: INSECUR S.A. — Laboratorio: TryHackMe

Seguridad Aplicada a Sistemas de Informacion — UCH

Docente: Ing. Rodrigo Atilio Elgueta

Federico Garcia

10 de octubre de 2026

Índice

1. Datos generales	2
2. Resumen ejecutivo	2
3. Pre-pentesting	3
4. Hallazgos — Basic Pentesting	4
5. Hallazgos — Vulniversity	12
6. Recomendaciones	16
7. Protocolo de contingencia	16
8. Anexos	16
9. Referencias	17

1. Datos generales

Campo	Valor
Cliente	INSECUR S.A.
Contratista (alumno)	Federico Garcia
DNI	(omitido: repositorio publico)
Username TryHackMe	federico.garcia.uch
Correo institucional	federico.garcia@alumno.uch.edu.ar
Sala obligatoria (Nivel 1)	Pentesting Fundamentals (metodologica) — completada
Sala obligatoria (Nivel 1)	Basic Pentesting — completada
Sala de eleccion (Nivel 2)	Vulnversity — completada
Objetivo Basic Pentesting	10.65.166.39 (SO Linux, Ubuntu 20.04)
Objetivo Vulnversity	IP rotativa asignada por THM (SO Linux, Ubuntu 20.04)
Branch en GitHub	garcia-federico
Fecha de inicio	2026-10-08
Fecha de ejecucion (Basic)	2026-10-09
Fecha de ejecucion (Vulnversity)	2026-10-10
Fecha de cierre	2026-10-10
Estado	Completo (Basic Pentesting y Vulnversity finalizadas)

2. Resumen ejecutivo

Sintesis

Se desarrollo una evaluacion de pentesting de alcance acotado sobre los laboratorios autorizados de TryHackMe, en el marco de la actividad academica A08. **Pentesting Fundamentals** aporoto el marco metodologico (teorico). Sobre la maquina de **Basic Pentesting** (10.65.166.39) se completo el ciclo de intrusion de extremo a extremo: reconocimiento de servicios, enumeracion, acceso inicial, movimiento lateral y escalada de privilegios hasta obtener control total (root).

El hallazgo de mayor severidad es la combinacion de una **clave SSH privada legible por otros usuarios** y una **cuenta con privilegios sudo sin restriccion**, que en conjunto permiten pasar de un usuario sin privilegios a **root**. Dicho de otro modo: a partir de una contraseña SSH debil, un atacante obtiene una cuenta local y, encadenando malas configuraciones, logra el compromiso completo del host. Las recomendaciones centrales son corregir los permisos de las claves privadas, restringir **sudo** al minimo necesario y reforzar la politica de contraseñas.

En la maquina de **Vulnversity** se completo un segundo ciclo de intrusion de extremo a extremo: reconocimiento de servicios, enumeracion web, explotacion de una **subida de ar-**

chivos con validacion de extensiones por lista negra incompleta (acepta .phtml) para obtener una shell como **www-data**, y **escalada a root** abusando del binario **systemctl** con bit SUID. El impacto es, nuevamente, compromiso total del host. En conjunto, ambas maquinas evidencian que los compromisos criticos rara vez surgen de una unica falla, sino del encadenamiento de varias malas configuraciones.

Resumen de resultados por severidad

Clasificacion propia (CVSS v3.1 estimado) de los 14 resultados documentados. La severidad individual no refleja el impacto en cadena: en ambas maquinas, resultados de severidad media encadenados culminan en compromiso total (Critico).

Clasificacion	Cantidad
Critica	1
Alta	3
Media	7
Baja	2
Informativa	1
Total	14

Critica: H-12 (RCE via upload). Altas: H-07 (clave world-readable), H-10 (sudo ALL:ALL, requiere acceso local) y H-14 (systemctl SUID). Medias: H-03, H-04, H-05, H-06, H-08, H-09, H-11. Bajas: H-01, H-02. Informativa: H-13 (evidencia de impacto, no vulnerabilidad). Se habla de “resultados” y no de “vulnerabilidades” porque H-11 es una condicion previa y H-13 una evidencia de impacto.

3. Pre-pentesting

Alcance

Maquinas de laboratorio que TryHackMe asigna para **Basic Pentesting** y **Vulniversity**, accesibles por la IP que la plataforma entrega via VPN. **Pentesting Fundamentals** se incluye como formacion metodologica (teorica, sin maquina, no genera hallazgos tecnicos). Fuera de alcance: todo sistema real o cualquier IP no asignada por la plataforma.

Reglas de Enfrentamiento (ROE)

Solo la IP asignada por TryHackMe via VPN (para Basic Pentesting: 10.65.166.39). Sin ataques de denegacion de servicio. Sin salir del alcance. Las pruebas de fuerza bruta se limitaron a un unico objetivo y usuario, con la wordlist estandar del laboratorio. **Supuesto adoptado:** al tratarse de un laboratorio academico de practica, se asume disponibilidad 24/7 de las maquinas y sin restriccion de ventana horaria ni limite de trafico mas alla del arrendamiento temporal que impone la plataforma; no aplican acuerdos de nivel de servicio de un entorno productivo real.

Autorizacion

Autorizacion de la catedra para A08 sobre los entornos de TryHackMe indicados en la guia. Las maquinas son de practica, intencionalmente vulnerables y provistas por la plataforma. No habilita acciones sobre sistemas reales ni de terceros.

Metodologia

NIST SP 800-115: sus cuatro fases (planificacion, descubrimiento, ataque y reporte) mapean con la estructura de este informe. La fase de ataque se documenta distinguiendo explicitamente: *servicio descubierto*, *vulnerabilidad demostrada*, *acceso obtenido* y *escalada de privilegios*. Para la parte web se usa OWASP WSTG como referencia.

Autenticidad de la evidencia

Username THM (federico.garcia.uch) visible en las capturas; evidencia organizada por fase en **evidencias/**; bitacoras de comandos en **bitacora/**; hash SHA-256 de flags en Anexo C; commits con identidad real en la rama **garcia-federico**. Las credenciales obtenidas (contrasenas, passphrase, clave privada) se tratan como material sensible y **no** se publican en el repositorio.

4. Hallazgos — Basic Pentesting

Objetivo: 10.65.166.39 (SO Linux, Ubuntu 20.04). **Herramientas y justificacion:** **nmap** (descubrimiento de puertos y deteccion de versiones); **smbclient** y **rpcclient** (enumeracion de recursos y usuarios por SMB/RPC); **enum4linux** (enumeracion SMB automatizada); **curl** (inspeccion y descarga de recursos web); **hydra** (prueba de credenciales por diccionario sobre SSH); **ssh2john + john** (extraccion y crackeo offline de la passphrase); **scp/ssh** (transferencia y acceso remoto). Cada una es la herramienta estandar de Kali para su fase y deja salida auditable para la bitacora.

Servicios detectados (verificados con evidencia propia):

Puerto	Servicio	Version / Detalle
22/tcp	SSH	OpenSSH 8.2p1 Ubuntu (protocolo 2.0)
80/tcp	HTTP	Apache 2.4.41 (Ubuntu)
445/tcp	microsoft-ds (SMB)	Samba 4.15.13, SMB 3.1.1

*Nota metodologica: se emplearon escaneos dirigidos a los puertos de interes (22, 80, 445). No se ejecuto un escaneo exhaustivo del rango completo (**nmap -p-**); se asume como limitacion metodologica reconocida y, por lo tanto, no se documentan servicios adicionales que no cuenten con evidencia propia verificada en esta ejecucion.*

H-01: Resolucion de nombres de usuario por SMB sin autenticacion

Campo	Valor
Fase	Enumeracion
Categoria del resultado	Vulnerabilidad demostrada (divulgacion de informacion)

Descripcion	El servicio SMB (445) admite una sesion nula (sin credenciales). Mediante <code>rpcclient</code> con el comando <code>lookupnames</code> se confirmo que <code>jan</code> y <code>kay</code> corresponden a cuentas de usuario validas (SID resueltos). <code>enum4linux</code> logro la sesion vacia pero no completo la enumeracion de usuarios, y <code>rpcclient enumdomusers</code> no devolvio resultados; por lo tanto no se afirma una enumeracion completa del dominio, solo la resolucion dirigida de nombres concretos.	
Componente	Samba / SMB (puerto 445)	
Categoria	CWE-200 (Exposure of Sensitive Information)	
Herramienta	<code>rpcclient -U " " -N (lookupnames); enum4linux</code>	
Impacto CIA	Confidencialidad (nombres de usuario validos facilitan ataques dirigidos de credenciales).	
Salvaguarda	Restringir el acceso anonimo a SMB (<code>restrict anonymous = 2 / map to guest = Never</code> en <code>smb.conf</code>); limitar el puerto 445 por firewall a redes de confianza; deshabilitar SMB si el host no comparte archivos.	
Severidad	Baja (CVSS 3.1 est.)	
Riesgo residual	Bajo (tras restringir la sesion nula).	
Evidencia	<code>evidencias/escaneo/bp_rpc_nombres.png</code> ; <code>bitacoras</code> <code>bp_rpc_nombres.txt</code> , <code>bp_smb_usuarios.txt</code> .	

H-02: SMB con firma de mensajes no obligatoria

Campo	Valor
Fase	Escaneo
Categoria del resultado	Debilidad de configuracion (no se demostro explotacion)
Descripcion	El script <code>smb2-security-mode</code> de <code>nmap</code> reporta "Message signing enabled but not required" sobre SMB 3.1.1. La firma esta disponible pero el servidor no la exige, lo que constituye una debilidad de configuracion que podria habilitar ataques de tipo man-in-the-middle / relay. No se realizo ni se demostro un ataque de relay en esta evaluacion.
Componente	Samba / SMB (puerto 445)
Categoria	CWE-300 (Channel Accessible by Non-Endpoint)

Herramienta	nmap -p445 --script smb2-security-mode
Impacto CIA	Integridad y Confidencialidad (potencial, no demostrado).
Salvaguarda	Exigir firma SMB (server signing = mandatory); segmentar la red para reducir la exposicion a relay.
Severidad	Baja (CVSS 2.6 est.)
Riesgo residual	Bajo.
Evidencia	evidencias/escaneo/bp_smb_signing.png; bitacora bp_smb_signing.txt.

H-03: Directorio web con listado y notas internas expuestas

Campo	Valor
Fase	Escaneo / Enumeracion
Categoria del resultado	Vulnerabilidad demostrada (divulgacion de informacion)
Descripcion	El directorio <code>/development/</code> (puerto 80) responde HTTP 200 con listado de directorio habilitado, exponiendo <code>dev.txt</code> y <code>j.txt</code> sin autenticacion. <code>dev.txt</code> contiene notas internas (menciones a Apache, configuracion de SMB y una referencia a Apache Struts 2.5.12). <code>j.txt</code> es una nota entre miembros del equipo indicando que una contrasena era debil y debia cambiarse. Aclaracion: la mencion a Struts 2.5.12 es una referencia en una nota de texto; no se verifico que ese componente este desplegado ni es explotable, por lo que no se asigna CVE.
Componente	Apache 2.4.41 (puerto 80)
Categoria	CWE-548 (Information Exposure Through Directory Listing)
Herramienta	curl (listado y descarga de dev.txt / j.txt)
Impacto CIA	Confidencialidad (exposicion de informacion interna y pistas de credenciales debiles).
Salvaguarda	Deshabilitar el listado de directorios (Options -Indexes); remover o proteger con autenticacion los directorios de desarrollo en produccion; revisar permisos de los recursos publicados.
Severidad	Media (CVSS 4.0 est.)

Riesgo residual	Bajo-Medio.
Evidencia	bitacoras <code>bp_development.txt</code> , <code>bp_dev.txt</code> , <code>bp-j.txt</code> .

H-04: Acceso anonimo a recurso compartido SMB y fuga de informacion

Campo	Valor
Fase	Enumeracion / Acceso a datos
Categoria del resultado	Vulnerabilidad demostrada (acceso no autenticado + divulgacion)
Descripcion	El servidor expone un recurso compartido Anonymous accesible sin credenciales. Se accedio y se descargo staff.txt , un aviso interno al personal que menciona nominalmente a Jan y Kay , confirmando la existencia de esas cuentas y relacionando usuarios.
Componente	Samba / SMB (recurso Anonymous)
Categoria	CWE-306 (Missing Authentication for Critical Function)
Herramienta	smbclient (-L, ls, get)
Impacto CIA	Confidencialidad (acceso no autenticado a archivos y divulgacion de informacion interna).
Salvaguarda	Eliminar el recurso Anonymous o exigir autenticacion; aplicar valid users y permisos minimos; no almacenar informacion interna en shares de acceso publico.
Severidad	Media (CVSS 5.3 est.)
Riesgo residual	Bajo (tras exigir autenticacion).
Evidencia	evidencias/escaneo/bp_smb_anonymous.png; bitacoras <code>bp_smb_recursos.txt</code> , <code>bp_smb_anonymous.txt</code> , <code>bp_smb_descarga.txt</code> , <code>bp_staff.txt</code> .

H-05: Contraseña SSH debil del usuario jan (fuerza bruta)

Campo	Valor
Fase	Explotacion

Categoría del resultado	Vulnerabilidad demostrada (credencial debil)
Descripción	Siguiendo la pista de <code>j.txt</code> (H-03), se realizó una prueba de diccionario autorizada contra la cuenta <code>jan</code> por SSH usando la wordlist <code>rockyou.txt</code> . La prueba encontró un único par válido de credenciales. El servicio no presenta mecanismo de bloqueo tras intentos fallidos. La contraseña no se incluye en el informe ni en el repositorio público.
Componente	OpenSSH 8.2p1 (puerto 22) + política de contraseñas
Categoría	CWE-521 (Weak Password Requirements); CWE-307 (No restricción de intentos)
Herramienta	<code>hydra -l jan -P rockyou.txt ssh://</code>
Impacto CIA	Confidencialidad e Integridad (habilita acceso remoto autenticado).
Salvaguarda	Política de contraseñas robusta; autenticación por clave pública y deshabilitar password auth en SSH; mecanismos de bloqueo/retardo (fail2ban) ante intentos fallidos.
Severidad	Media (CVSS 6.5 est.)
Riesgo residual	Medio (mientras persista password auth con contraseñas débiles).
Evidencia	<i>Privada</i> (muestra la contraseña): bitacora <code>bp_hydra.txt</code> y captura <code>evidencia_hydra.png</code> conservadas fuera del repositorio público.

H-06: Acceso inicial obtenido como jan

Campo	Valor
Fase	Explotación
Categoría del resultado	Acceso obtenido (usuario sin privilegios)
Descripción	Con la credencial de H-05 se inició sesión por SSH como <code>jan</code> , obteniendo una shell interactiva en el objetivo. Se verificó la identidad con <code>id</code> (<code>uid=1001(jan)</code>), <code>hostname</code> (<code>ip-10-65-166-39</code>) y <code>date</code> . La cuenta no pertenece al grupo <code>sudo</code> .
Componente	OpenSSH / sistema operativo

Categoría	Consecuencia directa de H-05
Herramienta	ssh (cliente)
Impacto CIA	Confidencialidad e Integridad (acceso valido al sistema como usuario local).
Salvaguarda	Las mismas de H-05 (clave publica, bloqueo de intentos, politica de contraseñas).
Severidad	Media (CVSS 6.5 est.)
Riesgo residual	Medio.
Evidencia	evidencias/explotacion/bp_ssh_acceso.png; bitacora bp_ssh_acceso.txt.

H-07: Clave SSH privada legible por otros usuarios (movimiento lateral jan a kay)

Campo	Valor
Fase	Post-explotacion / Movimiento lateral
Categoría del resultado	Vulnerabilidad demostrada + acceso obtenido (segundo usuario)
Descripción	Desde la shell de jan se observo que /home/kay/.ssh/id_rsa tiene permisos -rw-r--r-- (legible por cualquier usuario). Una clave privada nunca deberia ser legible por terceros (deberia ser 600). Se copio la clave y, tras recuperar su passphrase (H-08), se inicio sesion por SSH como kay, logrando el movimiento lateral a una segunda cuenta.
Componente	Permisos de archivo / OpenSSH
Categoría	CWE-732 (Incorrect Permission Assignment for Critical Resource)
Herramienta	ls -la; scp; ssh -i
Impacto CIA	Confidencialidad e Integridad (suplantacion de un segundo usuario del sistema).
Salvaguarda	Permisos 600 (propietario) en claves privadas; auditoria periodica de permisos en ~/.ssh; proteger las claves con passphrase robusta.
Severidad	Alta (CVSS 8.1 est.)

Riesgo residual	Alto hasta corregir permisos.
Evidencia	<code>evidencias/explotacion/bp_scp_clave.png</code> , <code>evidencias/explotacion/bp_kay_login.png</code> . <i>La clave privada en si se conserva fuera del repositorio publico.</i>

H-08: Passphrase debil en la clave SSH privada

Campo	Valor
Fase	Explotacion (offline)
Categoria del resultado	Vulnerabilidad demostrada (secreto debil)
Descripcion	La clave privada de kay estaba cifrada con una passphrase. Convertida a formato atacable con ssh2john , se recupero la passphrase con john y la wordlist rockyou.txt en menos de un segundo, lo que evidencia una passphrase trivial. El valor de la passphrase no se incluye en el repositorio publico.
Componente	Clave SSH privada de kay
Categoria	CWE-521 (Weak Password/Passphrase Requirements)
Herramienta	<code>ssh2john</code> ; <code>john --wordlist=rockyou.txt</code>
Impacto CIA	Confidencialidad (una passphrase debil no protege la clave si esta es legible — ver H-07).
Salvaguarda	Passphrase robusta en toda clave privada; rotacion de claves comprometidas; el control de permisos (H-07) es la defensa primaria.
Severidad	Media (CVSS 5.9 est.)
Riesgo residual	Medio.
Evidencia	<i>Privada</i> (muestra la passphrase): captura <code>bp_john_passphrase.png</code> conservada fuera del repositorio publico.

H-09: Credencial almacenada en texto plano

Campo	Valor
-------	-------

Fase	Post-explotacion
Categoria del resultado	Vulnerabilidad demostrada (almacenamiento inseguro de credenciales)
Descripcion	En el directorio home de kay existe el archivo pass.bak , que almacena una contrasena en texto plano. Como kay , se accedio a su contenido. El valor no se transcribe en el informe ni se publica en el repositorio.
Componente	Sistema de archivos / practica del usuario
Categoria	CWE-312 (Cleartext Storage of Sensitive Information)
Herramienta	cat
Impacto CIA	Confidencialidad (exposicion directa de una credencial valida).
Salvaguarda	No almacenar contrasenas en archivos de texto; usar gestores de secretos; eliminar backups de credenciales; concientizacion de usuarios.
Severidad	Media (CVSS 5.5 est.)
Riesgo residual	Medio.
Evidencia	Documentado en texto; el valor se omite deliberadamente.

H-10: Privilegios sudo sin restriccion (escalada a root)

Campo	Valor
Fase	Escalada de privilegios
Categoria del resultado	Escalada de privilegios (compromiso total)
Descripcion	sudo -l para kay devuelve (ALL : ALL) ALL: la cuenta puede ejecutar cualquier comando como root . Se ejecuto sudo -i y se obtuvo una shell con uid=0(root) , confirmando el compromiso completo del sistema.
Componente	Configuracion de sudo (/etc/sudoers)
Categoria	CWE-269 (Improper Privilege Management)
Herramienta	sudo -l; sudo -i; id
Impacto CIA	Confidencialidad, Integridad y Disponibilidad (control administrativo total del host).

Salvaguarda	Aplicar minimo privilegio en sudoers: otorgar solo los comandos estrictamente necesarios; evitar (ALL:ALL) ALL; registrar y auditar el uso de sudo.
Severidad	Alta (CVSS 7.8 est.; requiere acceso local)
Riesgo residual	Alto hasta restringir sudoers.
Evidencia	evidencias/post/bp_sudo_l_y_bp_root.png.

Cadena de ataque (resumen)

Recon (SMB, HTTP, SSH) a **H-01/H-03/H-04** divulgacion de usuarios y notas internas a **H-05** contraseña SSH debil de **jan** a **H-06** acceso inicial como **jan** a **H-07/H-08** clave privada de **kay** legible + passphrase debil a movimiento lateral a **kay** a **H-09** credencial en texto plano a **H-10** sudo (ALL:ALL) a **root**. El impacto agregado de la cadena es **compromiso total del sistema (Critico)**, aunque cada hallazgo individual tiene la severidad indicada en su ficha.

5. Hallazgos — Vulnversity

Objetivo: maquina de Vulnversity (SO Linux, Ubuntu 20.04; IP rotativa asignada por THM).
Herramientas y justificacion: **nmap** (descubrimiento de puertos y versiones); **gobuster** (enumeracion de directorios web por diccionario); **curl** (subida del archivo al formulario); **netcat** (listener de la reverse shell); reverse shell PHP (payload de ejecucion); **python3** (estabilizacion de la shell); **systemctl** (abusado via SUID para la escalada). Elegidas por adecuarse a cada fase del ataque web y dejar evidencia reproducible.

Servicios detectados (nmap -sV):

Puerto	Servicio	Version / Detalle
21/tcp	FTP	vsftpd 3.0.5
22/tcp	SSH	OpenSSH 8.2p1 Ubuntu
139/445	SMB	Samba smbd 4
3128/tcp	Proxy HTTP	Squid http proxy 4.10
3333/tcp	HTTP	Apache httpd 2.4.41 (servidor web)

*El servidor web corre en un puerto no estandar (3333); el puerto 80 esta cerrado. Limitacion metodologica: el escaneo se dirige a los puertos tipicos de la sala; no se conserva salida de un escaneo exhaustivo **nmap -p-** de los 65535 puertos, dado que la maquina es de arrendamiento temporal.*

H-11: Directorio de carga de archivos expuesto

Campo	Valor
Fase	Enumeracion

Categoría del resultado	Observación / condición previa (habilita H-12)
Descripción	La enumeración de directorios con gobuster sobre el sitio del puerto 3333 reveló el directorio <code>/internal/</code> , que aloja un formulario de subida de archivos (<code>index.php</code> , campo <code>name=file</code>) accesible sin autenticación. <i>Por si solo es una observación de superficie de ataque; su relevancia es ser la condición previa que habilita el hallazgo crítico H-12.</i>
Componente	Apache 2.4.41 (puerto 3333)
Categoría	CWE-200 (Exposure of Sensitive Information)
Herramienta	gobuster dir
Impacto CIA	Confidencialidad (expone una funcionalidad sensible sin control de acceso).
Salvaguarda	Proteger con autenticación los directorios internos; no exponer formularios de carga sin control de acceso; restringir por red.
Severidad	Media (CVSS 5.3 est.)
Riesgo residual	Medio (habilita H-12).
Evidencia	bitacora vv_gobuster.txt.

H-12: Subida de archivos con validación de extensión por lista negra incompleta

Campo	Valor
Fase	Explotación
Categoría del resultado	Acceso obtenido (RCE / shell como www-data)
Descripción	El formulario de <code>/internal/</code> valida la extensión del archivo mediante una lista negra incompleta: bloquea <code>.php</code> pero acepta <code>.phtml</code> , extensión que Apache ejecuta igualmente como PHP. Se subió una reverse shell PHP con nombre <code>shell.phtml</code> (respuesta <i>Success</i>) y, al acceder a <code>/internal/uploads/shell.phtml</code> , el servidor la ejecutó y estableció una conexión inversa hacia la máquina atacante, obteniendo una shell como www-data (<code>uid=33</code>).
Componente	Lógica de validación del upload (<code>index.php</code>)

Categoría	CWE-434 (Unrestricted Upload of File with Dangerous Type)
Herramienta	curl (subida); netcat (listener); python3 (estabilizacion de shell)
Impacto CIA	Confidencialidad, Integridad y Disponibilidad (ejecucion remota de codigo en el servidor).
Salvaguarda	Validar por lista blanca de extensiones permitidas; verificar el tipo real de contenido (MIME/magic bytes); almacenar los archivos subidos fuera de la raiz web o sin permisos de ejecucion; renombrar los archivos al guardarlos.
Severidad	Critica (CVSS 9.8 est.)
Riesgo residual	Alto hasta corregir la validacion.
Evidencia	evidencias/vulniversity/vv_shell_wwwdata.png.

H-13: Flag de usuario accesible por www-data

Campo	Valor
Fase	Post-explotacion
Categoría del resultado	Evidencia de impacto de H-12 (no es vulnerabilidad independiente)
Descripción	Desde la shell de www-data se accedio al archivo user.txt en el home del usuario que administra el servidor, obteniendo la flag de usuario. El valor no se publica; se registra su hash SHA-256 en el Anexo C.
Componente	Sistema de archivos / permisos
Categoría	Consecuencia de H-12
Herramienta	cat
Impacto CIA	Confidencialidad.
Salvaguarda	Minimo privilegio sobre archivos sensibles; evitar que la cuenta del servicio web pueda leer datos de otros usuarios.
Severidad	Informativa (no es vulnerabilidad; evidencia de impacto de H-12)
Riesgo residual	Medio.

Evidencia	Flag registrada como hash en <code>vv_flags_sha256.txt</code> (Anexo C).
-----------	--

H-14: Binario `systemctl` con bit SUID (escalada a root)

Campo	Valor
Fase	Escalada de privilegios
Categoría del resultado	Escalada de privilegios (compromiso total)
Descripción	La búsqueda de binarios con bit SUID (<code>find / -perm -4000 -type f</code>) reveló que <code>/bin/systemctl</code> tiene SUID, lo que permite a cualquier usuario invocarlo con privilegios de root. Se creó un servicio <code>systemd</code> malicioso en <code>/tmp/root.service</code> cuyo <code>ExecStart</code> lee <code>/root/root.txt</code> y lo copia a una ruta legible; con <code>systemctl link</code> y <code>systemctl start</code> ejecutado como root se obtuvo la flag de root, confirmando el compromiso total del sistema.
Componente	Permisos de <code>/bin/systemctl</code>
Categoría	CWE-269 (Improper Privilege Management) — SUID indebido
Herramienta	<code>find</code> ; <code>systemctl</code> (<code>link/start</code>)
Impacto CIA	Confidencialidad, Integridad y Disponibilidad (control administrativo total).
Salvaguarda	Retirar el bit SUID de <code>systemctl</code> (<code>chmod u-s</code>); auditar periódicamente los binarios SUID del sistema; aplicar mínimo privilegio.
Severidad	Alta (CVSS 7.8 est.)
Riesgo residual	Alto hasta retirar el SUID.
Evidencia	<code>evidencias/vulniversity/vv_suid_find.png</code> , <code>evidencias/vulniversity/vv_root.png</code> .

Cadena de ataque Vulniversity (resumen)

Recon (FTP, SSH, SMB, Squid, Apache:3333) a **H-11** directorio `/internal/` con formulario de carga a **H-12** subida de `.phtml` (lista negra incompleta) y reverse shell a **acceso como www-data** a **H-13** flag de usuario a **H-14** `systemctl` SUID a **root**. Impacto agregado: **compromiso total del sistema (Crítico)**.

6. Recomendaciones

Técnicas

Corregir permisos de claves privadas a 600 (H-07); restringir `sudo` al mínimo necesario, evitando (ALL:ALL) ALL (H-10); eliminar credenciales en texto plano y backups de contraseñas (H-09); reforzar la política de contraseñas y passphrases y preferir autenticación por clave pública, deshabilitando password auth en SSH (H-05, H-08); restringir la sesión nula y exigir firma en SMB, y eliminar o autenticar el recurso Anonymous (H-01, H-02, H-04); deshabilitar el listado de directorios y proteger `/development/` (H-03); limitar por firewall los puertos expuestos a redes de confianza; mantener actualizados Apache, OpenSSH y Samba.

Específicas de Vulnversity: validar las subidas de archivos por lista blanca de extensiones y por tipo real de contenido, y almacenarlas fuera de la raíz web o sin permiso de ejecución (H-12); proteger con autenticación los directorios internos (H-11); retirar el bit SUID de `systemctl` y auditar periódicamente los binarios SUID (H-14).

Administrativas

Política de gestión de parches; revisión periódica de servicios expuestos y de permisos en directorios sensibles; principio de mínima exposición (cerrar servicios no utilizados) y mínimo privilegio; concientización de usuarios sobre manejo de credenciales.

7. Protocolo de contingencia

Escenario y respuesta

Escenario: compromiso de un servidor web expuesto mediante subida de archivos maliciosos (como el demostrado en Vulnversity), con posterior escalada a root. **Detección:** monitoreo de integridad de archivos en los directorios de carga, alertas ante la creación de archivos ejecutables en rutas de uploads, y revisión de logs de Apache y de uso de `sudo/systemctl`. **Contención:** aislar el host de la red, suspender el servicio afectado y preservar evidencia (imagen de disco y logs). **Recuperación:** restaurar desde una copia de seguridad limpia anterior al compromiso, aplicar las correcciones de las recomendaciones (lista blanca de uploads, retiro de SUID, permisos de claves, sudoers mínimo) y rotar credenciales potencialmente expuestas. **Comunicación:** notificar al responsable del sistema y documentar el incidente.

Objetivos de recuperación (referenciales)

Valores a acordar con el cliente según criticidad del servicio. Como referencia para un servicio web no crítico de laboratorio: **RTO** (tiempo máximo de recuperación) del orden de 4–8 horas; **RPO** (pérdida máxima de datos tolerable) del orden de 24 horas, consistente con copias de seguridad diarias. *Estos valores son orientativos y deben ajustarse al acuerdo de nivel de servicio real.*

8. Anexos

Anexo A — Bitacora

Salidas de comandos en `bitacora/` (prefijo `bp_` para Basic Pentesting): conectividad, escaneos nmap, enumeración SMB/rpc, acceso web, acceso SSH, movimiento lateral y escalada. Las

bitacoras que contienen secretos (p.ej. la salida de hydra) se conservan fuera del repositorio publico.

Anexo B — Capturas

En evidencias/:

- escaneo/bp_smb.signing.png — firma SMB no obligatoria (H-02).
- escaneo/bp_rpc.nombres.png — resolucio de usuarios jan/kay (H-01).
- escaneo/bp_smb.anonymous.png — acceso anonimo a SMB y staff.txt (H-04).
- explotacion/bp_ssh.acceso.png — acceso inicial como jan (H-06).
- explotacion/bp_scp.clave.png — obtencion de la clave de kay (H-07).
- explotacion/bp_kay.login.png — login como kay (H-07).
- post/bp_sudo.l_y_bp_root.png — sudo (ALL:ALL) y shell root (H-10).
- basic_pentesting_completada.png — sala completada (usuario federico.garcia.uch).
- fundamentals_completada.jpeg — Pentesting Fundamentals completada.
- vulnversity/vv_shell.wwwdata.png — shell como www-data via upload (H-12).
- vulnversity/vv_suid.find.png — binario systemctl con SUID (H-14).
- vulnversity/vv_root.png — escalada a root y flag (H-14).
- vulnversity/vv_room.completada.png — Vulnversity completada (usuario federico.garcia.uch).

Evidencias privadas (no publicadas por contener secretos): captura de hydra y de la passphrase recuperada con john.

Anexo C — Hashes de flags

```
# Vulnversity - SHA-256 de las flags (sin salto de linea)
# user.txt
d324bd433001e5bdfce39e04d794539c15b51982a5bf6fc78efea46369b7bf956
# root.txt
cfbc740435ad60030304080e35131ffcaf8ac5f71b65e002f5b546aa3cda7ce8
```

Anexo D — Declaracion etica

Declaro que todas las actividades se realizaron dentro del alcance autorizado, en entornos controlados y con fines academicos.

/s/ Federico Garcia

10 de octubre de 2026

Firma

Fecha

9. Referencias

Fuentes y bibliografia

- NIST SP 800-115 — *Technical Guide to Information Security Testing and Assessment*. National Institute of Standards and Technology. <https://csrc.nist.gov/pubs/sp/800/115/final>
- OWASP Web Security Testing Guide (WSTG). <https://owasp.org/www-project-web-security-testing-guide/>
- MITRE CWE — Common Weakness Enumeration (CWE-200, 269, 300, 306, 312, 434,

- 521, 548, 732). <https://cwe.mitre.org/>
- FIRST — Common Vulnerability Scoring System (CVSS) v3.1. <https://www.first.org/cvss/>
 - Documentacion oficial de herramientas: Nmap (<https://nmap.org/book/>), GNU/THC Hydra, John the Ripper (<https://www.openwall.com/john/>), Gobuster, Samba, OpenSSH, systemd/systemctl.
 - TryHackMe — Salas Pentesting Fundamentals, Basic Pentesting y Vulnversity. <https://tryhackme.com/>
 - Referencias de remediacion: CIS Benchmarks (Ubuntu Linux) y guias de hardening de OpenSSH y Samba.